

D3 Finance · 资金安全与钱包策略指南

Turnkey 多签托管 · BSC 链上资金架构 · 策略与进出流转
组织 ID 0d7c1494-3b4e-42f7-a054-cde8a9cd8049 · 链 BNB Smart Chain (chainId 56) · 测试部署
生成日期 2026-07-18 · 本文档反映当前实际链上/Turnkey 配置

1. 安全模型总览

资金分两层托管:**热钱包(运营层)**由后端 API 用户 **自动签名**,只能做被策略严格限定的日常动作;**金库(储备层)**受 2/3 多签保护,任何转出都必须 3 个 root 签署人里的 2 个批准。后端 key 永远无法单独动金库。

1.1 参与方

角色	邮箱	Turnkey User ID	权能
Root 签署人 ①	y13311119143@gmail.com DA	eda9c451-aaef-4488-974c-c3e67baf8dbd	多签成员
Root 签署人 ②	lihui552713@gmail.com Ye	2825481a-5ae2-41a5-90f5-de855640c9a7	多签成员
Root 签署人 ③	bigtree777888@gmail.com DADA	c8c18268-8418-4389-899e-db807a48c897	多签成员
后端 API 用户	d3finance@hotmail.com Root user	5eba34d3-7b27-4a41-8192-49d80438cb54	持后端 API key,仅热钱包自动签;不在多签内

1.2 Root 多签门槛

项目	值
Root Quorum 门槛	2 / 3(3 个签署人中任意 2 个批准即通过)
治理动作(建策略 / 改多签 / 加支付卡 / 金库转账 / 删用户)	都需 2/3 多签
发起方式	1 人发起 → 变成待批准活动 → 另 1 人 Approve → 执行

2. 钱包清单与参数

钱包	地址	数量	签名方式
金库 Treasury D3-Treasury · 储备	0x2802A588F575Cb040487Dc0bD9e45b58c62C3B0B	1	2/3 多签
闪兑 Flash-Swap D3-FlashSwap · 兑付	0x84C973a3a072f4509623Bf273A4f64692fAB366A	1	后端自动签
Gas 钱包 D3-Gas · 手续费	0x1f738B91DA08db0C6A862d338579814eB8B836c9	1	后端自动签
结算 Settlement D3-Settlement 1-5 · 归集中转	0xB6dc457E0242454aB8C0C7ADe1c3A561bCE4538 0x3E6B6E64999da0AcB2Fd6DBff0f81E95D0A63F4A 0xEae0aBd36DbB676B5b54A18CaB40Dc87A90a8955 0x00f66206dCb1a0cB9FFf5a9495B9a43F828Ed4be 0x778eCADd6b9cDe07acd8e96dD3c1688141e7f053	5	后端自动签
入金池 Deposit HD 派生 · 每用户独立	HD 父钱包 0xe8917f817a0d31A3bB5cFe9Dbf8eef7418758184 派生路径 m/44'/60'/0'/0/n	200	后端自动签

代币与确认 · 结算币 USDT(BEP-20)0xE763F2dF7C8aDF28eAa34683245e3a6f82fc2512 · 链上确认要求 12 个区块后才认定入账/兑付(防重组回滚)。

3. 资金进出流转



3.1 各钱包进 / 出明细

钱包	资金进(IN)	资金出(OUT)	控制
入金池 Deposit	用户充值 USDT	$\rightarrow$ 结算钱包(归集)	自动
结算 Settlement	$\leftarrow$ 入金池归集	$\rightarrow$ 金库(≥ 100 USDT) $\rightarrow$ 闪兑(10%)	自动
闪兑 Flash-Swap	$\leftarrow$ 结算(10% 分流)	$\rightarrow$ 用户(收益兑付 / 提现)	自动
Gas 钱包	人工充值 BNB	$\rightarrow$ 各热钱包补手续费(BNB)	自动
金库 Treasury	$\leftarrow$ 结算(≥ 100 USDT 沉淀)	$\rightarrow$ 外部(唯一出口, 须 2/3 多签)	2/3

3.2 关键参数

参数	值	作用
Gas 补充触发线	余额 < 0.0005 BNB	热钱包 BNB 不足时自动补
Gas 单次补充	0.0005 BNB(策略上限 0.05 BNB)	每次补给量
结算 $\rightarrow$ 金库 门槛	≥ 100 USDT	结算钱包沉淀到金库的最小额
结算 $\rightarrow$ 闪兑 分流	10%	预留给兑付/提现的比例
链上确认	12 区块	入账与兑付的最终性要求

4. 当前 Turnkey 策略(实际生效)

以下 3 条为后端 API 用户(d3finance)的自动签授权,均 仅需 d3finance 本人(consensus = 该用户),被条件严格限定:

策略名	效果	批准	限定条件
-----	----	----	------

d3-backend-manage-wallets	ALLOW	d3finance	仅 CREATE_WALLET / CREATE_WALLET_ACCOUNTS(建钱包、派生入金地址)。不含任何转账签名。
d3-backend-native-gas	ALLOW	d3finance	链 56 · 发送方 ∈ 热钱包白名单 · 无 calldata(纯转 BNB) · 金额 ≤ 0.05 BNB。用于给热钱包补 gas。
d3-backend-usdt-transfer	ALLOW	d3finance	链 56 · 收款 = USDT 合约 · 函数选择器 0xa9059cbb(transfer) · 发送方 ∈ 热钱包白名单。 金库被排除在白名单外 ,故后端无法自动转出金库。

设计要点 · 三条策略把后端能签的动作压缩到「只能从热钱包按 ERC-20 transfer 转 USDT + 补 BNB gas + 建钱包」。金库地址不在任何自动签白名单里 —— 这是金库只能走 2/3 多签的根本保证。

5. 待办与安全建议

⚠ 建议一:补回「默认拒绝」兜底策略

原先的 d3-backend-deny-everything-else(EFFECT_DENY,condition=true)在近期面板操作中被删除了。当前 Turnkey 默认仍是「未授权即拒绝」,所以没有立即漏洞;但作为纵深防御,建议由 2/3 签署人重新建一条 DENY 兜底策略,防止未来误加宽松策略。

⚠ 建议二:金库转出仍缺一条「发起人 + 2/3」策略(未创建)

要让后端在管理后台「发起」金库转账、再由 2/3 批准执行,需要 root 签署人在面板新建一条 ALLOW 策略:
effect: EFFECT_ALLOW · condition: eth.tx.from == 金库地址(或 true) · consensus: 3 个 root 里 ≥ 2 个批准
建这条策略本身也走 2/3 流程(1 人发起、1 人批准),与「加支付卡」完全相同。建好后,金库转账链路即打通。

✓ **日常运营不受影响** · 用户入金归集、收益兑付、gas 补充全部走热钱包自动签,不需要多签、不需要付费。多签只作用于「从金库往外转储备资金」这一种高风险动作。

D3 Finance 内部安全文档 · 地址与参数以链上/Turnkey 实际配置为准 · 正式上线前将清空测试数据重新部署。